

4.1 INTRODUÇÃO

Os ataques realizados contra organizações de saúde têm se intensificado, devido o alto valor dos dados de saúde que podem valer até 50 vezes mais do que dados de cartão de crédito no mercado ilegal, em grande parte porque, em casos de ransomware (FONSECA, 2025).

O trabalho realiza um diagnóstico inicial de maturidade da clínica Centro Médico Integrado Saúde & Tecnologia (CMIST), com o objetivo de servir de base para a futura estruturação de uma estratégia de defesa cibernética. Para que essa estratégia seja efetiva, é fundamental compreender as interações entre o ambiente interno da clínica e as pressões do ambiente externo, garantindo que a segurança esteja alinhada à realidade do negócio, compreendendo-a como um processo contínuo e não meramente um produto isolado (SCHNEIER, 2000), assim a eficiência desse programa depende dessa análise, para que os investimento em ferramentas não se tornem desperdício de dinheiro e ineficientes. A análise é feita com base em um levantamento de ativos de informação e na aplicação de um framework simplificado que avalia cinco dimensões: governança, maturidade, metodologia, tecnologia e pessoas. A organização estudada foi criada por Inteligência artificial, modelada a partir de padrões comuns em clínicas de médio porte no Brasil, e a análise considera as diretrizes da Lei Geral de Proteção de Dados (LGPD) e boas práticas de segurança da informação.

4.2 Caracterização da Organização

O **Centro Médico Integrado Saúde & Tecnologia Ltda (CMIST)** atua na saúde complementar (consultas, exames de imagem e pequenas cirurgias), com atendimento presencial (06h às 22h) e operação de telelaudos de urgência 24/7. De porte médio, a clínica fatura R\$1.500.000,00/mês e possui 80 colaboradores (20 médicos, 20 equipe de enfermagem, 15 recepção e 25 apoio administrativo). Seu orçamento de TI é altamente restrito, representando apenas 2,5% do faturamento.

Os ativos de informação críticos, cujo vazamento impacta a operação e viola a LGPD, englobam Dados Pessoais Identificáveis (PII) e Informações de Saúde (PHI) de 60 mil prontuários, além de notas fiscais e dados de convênios. Entre os ativos lógicos, destacam-se as credenciais de acesso (senha AWS, chaves de integração,

senhas de usuários) e a infraestrutura de autenticação (VPN IPsec, gestão de sessões do Prontuário Eletrônico e MFA restrito à TI).

Tecnologicamente, a operação depende de uma infraestrutura híbrida. Na nuvem (AWS EC2), hospeda o Prontuário Eletrônico (PEP) e o Banco SQL. Localmente, possui 40 estações de trabalho, Firewall corporativo, equipamentos de IoT Médica (Ressonâncias/Tomógrafos) e um servidor local (Windows Server 2019) processando o sistema de imagens PACS, que recebe arquivos pesados continuamente para análise remota dos radiologistas durante a madrugada.

Descrição da operação: A clínica opera com um fluxo presencial e contínuo de pacientes durante o período das 06:00h às 22:00h, com grande dependência do sistema de prontuário eletrônico hospedado na nuvem para a recepção na triagem, após isso os dados são armazenados em um banco de dados presente na nuvem. Os pacientes realizam procedimentos de imagem (Tomografias e Ressonâncias) e pequenas cirurgias. Os equipamentos geram arquivos digitais pesados que são enviados imediatamente para o servidor local. A operação de telelaudos funciona em regime 24/7. Durante a madrugada, os radiologistas remotos acessam o servidor da clínica para analisar os exames de urgência e redigir os diagnósticos.

4.3 Direcionadores Internos e Externos

De acordo com a função Govern do CSF 2.0 (NIST, 2024), antes de qualquer controle técnico é necessário entender o contexto do negócio e os fatores que influenciam a segurança da organização.

Direcionador	Tipo	Impacto para a organização
Objetivo de crescimento acelerado em tele laudos	Interno	Gera pressa na liberação de acessos remotos sem a segurança necessária
Gestão familiar e sem critério técnico	Interno	Regras de segurança são quebradas por pressão de lideranças médicas

Falta de política de segurança escrita	Interno	Cada colaborador age do seu jeito com senhas compartilhadas, WhatsApp para dados de pacientes
Risco ignorado, não gerenciado	Interno	Sem mapeamento de riscos ou plano de emergência, a clínica age só quando o problema aparece
Orçamento de TI limitado (2,5% do faturamento)	Interno	Impede investimentos em controles básicos como MFA e monitoramento
Equipe sem cultura de segurança	Interno	Colaboradores expõem dados dos pacientes sem perceber o risco
LGPD — Lei nº 13.709/2018	Externo	PII(Informações pessoais identificáveis) e PHI(Informações pessoais de saúde) exigem proteção formal - multas podem chegar a R\$ 50 milhões
Ataques frequentes ao setor de saúde	Externo	Ransomware e roubo de senhas de VPN são os ataques mais comuns em clínicas
Fornecedor do PACS sem controle de acesso	Externo	Acessa o servidor principal a qualquer hora com senha trivial
Médicos trabalhando remotamente	Externo	Dispositivos pessoais sem controle da clínica ampliam a superfície de ataque

4.4 Diagnóstico Inicial de Maturidade

O diagnóstico de maturidade da CMIST foi feito avaliando cinco dimensões fundamentais da segurança da informação. Para garantir o rigor metodológico exigido, os achados foram correlacionados com as funções centrais do **NIST Cybersecurity Framework (CSF) 2.0 (NIST, 2024)**, abrangendo as categorias de Govern, Identify, Protect, Detect, Respond e Recover. A análise revelou que a organização possui um número predominantemente nível 1, fortemente impactado pela governança e um orçamento restrito.

Dimensão	Situação atual	Nível
Governança (Govern)	Não existem políticas formais de segurança da informação. A alta gestão enxerga a área tecnológica como despesa operacional disponibilizando apenas 2,5%, o que prova que as decisões são no improviso e focadas no lucro.	1- Inicial
Maturidade (Identify)	Não existe investigação, devido a inexistência de práticas formais, mas também a organização não conta com um mapeamento de riscos	1 - Inicial
Metodologia(<i>Respond / Recover</i>)	Não há processos padronizados, tudo dentro da organização é feito no improviso para garantir a operação diária, sacrificando a segurança.	1 - Inicial
Tecnologia (<i>Protect / Detect</i>)	Tem firewall e backup, mas com MFA limitado para somente uma parte dos funcionários, senhas expostas no script e a rede está mal segmentada, com a rede das máquinas de ressonância sendo a mesma que a da recepção.	2 - Básico
Pessoas (<i>Protect</i>)	Sem treinamentos preventivos para os funcionários. Colaboradores mandam prontuários por WhatsApp e exportam dados para o Mailchimp e clicam em links sem verificar a possibilidade de ser um phishing.	1 - Inicial

4.5 PRINCIPAIS GAPS E PRIORIDADES

Os gaps foram priorizados com base no framework (NIST, 2024), que orienta a priorização fundamentada na gestão de riscos e no contexto do negócio. Diante de um cenário de orçamento restrito, seguiu-se a recomendação de focar em ações de baixo custo e alto impacto, otimizando os recursos para proteger ativos críticos e melhorar a resiliência operacional

gap	impacto	prioridade	justificativa
Acesso de Terceiros (Fornecedor PACS com AnyDesk)	Alto: Qualquer pessoa com o CNPJ da clínica pode acessar o "coração" da operação. Risco iminente de invasão sem rastro de auditoria.	Alta	PROTECT (PR.AA-01): Falta de controle, já que o fornecedor acessa sem nenhum tipo de auditoria.
VPN sem Múltiplo Fator de Autenticação (MFA)	Alto: O vazamento de uma única senha permite qualquer criminoso sequestrar 60 mil prontuários via ransomware	Alta	PROTECT (PR.AA-01): A ausência de uma autenticação de múltiplos fatores para ativos considerados críticos e restritos.
Fuga Ativa de Dados (Mailchimp e WhatsApp)	Alto: Violação ativa da LGPD com exposição de registros considerados sensíveis pela lei, sujeitando a clínica a multas milionárias da em caso de investigação da ANPD.	Alta	PROTECT (PR.DS-01): Falha na proteção e gestão da confidencialidade dos dados (PII e PHI) em trânsito e em plataformas não homologadas.
Backup vulnerável a ransomware	Alto: A senha que está exposta no <i>script</i> permite que um vírus destrua os dados locais e as cópias na nuvem simultaneamente.	Média	RECOVER (RC.RP-01): Falta um sistema de recuperação seguro e isolado
Programa de Conscientização em Segurança	Médio: A falta de instrução faz com que os próprios funcionários burlem os controles de segurança no dia a dia e facilitem ataques	Média	PROTECT (PR.AT-01): A falta de um treinamento adequado e contínuo referente aos riscos cibernéticos para os usuários da organização. Apesar de ter

	de cibercriminosos		um alto impacto a longo prazo, recebeu uma prioridade média frente a urgência de fechar portas técnicas imediatas com o baixo orçamento disponível.
--	--------------------	--	---

4.6 Conclusão

O presente trabalho cumpriu o seu papel de realizar uma análise inicial referente ao Centro Médico Integrado Saúde & Tecnologia Ltda (CMIST). A análise levou à conclusão que a organização se encontra predominantemente no nível 1 em quase todas as avaliações realizadas. A atuação da clínica no meio digital é realizada totalmente no improviso, com ausência severa de governança formalizada, metodologias de resposta a incidentes e programas de conscientização para os usuários.

O grande desafio encontrado nessa organização se refere não simplesmente à tecnologia e sim à cultura e ao financeiro. É visível o conflito presente na clínica entre a necessidade de agilidade e boas práticas de seguranças que acabam resultando na perda de agilidade em pro de manter um ambiente seguro, o que resulta em prática inseguras, como o uso de WhatsApp e Mailchimp para o tráfego de dados sensíveis (PII e PHI). Agravando esse cenário, o orçamento restrito de TI, de apenas 2,5% do faturamento, exige que as correções sejam extremamente estratégicas, focando em impacto e custo benefício antes de exigir grandes investimentos em ferramentas.

Logo, compreende-se que esse diagnóstico inicial atua como uma base fundamental para o desenvolvimento da segurança nessa organização. Conforme estabelecem as diretrizes do National Institute of Standards and Technology (NIST, 2024) na sua função de Governança (Govern), a segurança da informação não deve ser tratada como um produto isolado, exigindo um entendimento inicial do contexto do negócio e os riscos operacionais antes de incluir qualquer ferramenta tecnológica. Esse levantamento inicial servirá de base metodológica para a próxima etapa do projeto , a fim de no final ter um programa de cibersegurança bem estruturado.

REFERÊNCIAS

BRASIL. **Lei nº 13.709, de 14 de agosto de 2018**. Lei Geral de Proteção de Dados Pessoais (LGPD). Diário Oficial da União, Brasília, DF, 15 ago. 2018.

FONSECA, Fatima. Saúde é setor que mais sofre ataque cibernético. **NIC.br**, 28 fev. 2025. Disponível em:
<https://nic.br/noticia/na-midia/saude-e-setor-que-mais-sofre-ataque-cibernetico/>.
Acesso em: 21 abr. 2026..

SCHNEIER, Bruce. Secrets and lies: digital security in a networked world. Indianapolis: Wiley, 2000.

NATIONAL INSTITUTE OF STANDARDS AND TECHNOLOGY (NIST). **The NIST Cybersecurity Framework (CSF) 2.0**. Gaithersburg, MD: NIST, 2024. Disponível em: <https://doi.org/10.6028/NIST.CSWP.29>. Acesso em: 27 abr. 2026.